LEZIONE 01

# Cosa stai proteggendo, e da cosa

Prima di parlare di firewall e antivirus conviene mettersi d'accordo su quattro parole. Le uso in tutte le lezioni, e le sento confondere in quasi tutte le aziende.



A COLPO D'OCCHIO

**C**

**Riservatezza**

Solo chi è autorizzato legge l'informazione.

La viola: un furto di dati

**I**

**Integrità**

Nessuno altera l'informazione senza permesso.

La viola: un ransomware

**A**

**Disponibilità**

Il servizio risponde quando serve.

La viola: un guasto, un DDoS

**Rischio = probabilità × impatto.** La vulnerabilità è la porta aperta, l'exploit è chi ci passa.

## La sicurezza in tre parole: la triade CIA

Ogni misura di sicurezza serve a proteggere almeno una di **tre** proprietà:

- **C — Confidentiality (Riservatezza):** solo chi è autorizzato accede all'informazione. *Esempio:* cifratura del disco, permessi sui file, HTTPS.
- **I — Integrity (Integrità):** l'informazione non viene alterata senza autorizzazione. *Esempio:* hash/checksum, firme digitali, log append-only.
- **A — Availability (Disponibilità):** il servizio è raggiungibile quando serve. *Esempio:* ridondanza, backup, protezione anti-DDoS.

> Un attacco si può leggere sempre come **violazione** di C, I o A: un furto di dati viola C; un ransomware viola I e A; un DDoS viola A.

## Il vocabolario del rischio

Quattro parole che spesso si confondono:

| Termine | Significato | Esempio |
|---|---|---|
| **Minaccia** (threat) | *chi/cosa* potrebbe farti danno | un gruppo ransomware |
| **Vulnerabilità** | una *debolezza* sfruttabile | un software non aggiornato |
| **Exploit** | il *codice/tecnica* che sfrutta la vulnerabilità | il programma che attiva il bug |
| **Rischio** | probabilità × impatto | quanto è probabile e quanto farebbe male |

**Vulnerabilità ≠ exploit:** la vulnerabilità è la *porta aperta*, l'exploit è *passarci attraverso*.

**Zero-day:** una vulnerabilità **sfruttata prima** che sia nota al produttore o che esista una correzione (patch). È pericolosa perché non c'è ancora difesa ufficiale.

## Un esempio: un'azienda da cento persone

Prendiamo un'azienda tipica di quelle che seguo: cento persone, un gestionale, la posta su Microsoft 365, un file server, due linee di produzione con i loro PLC, un centralino.

| Sistema | Cosa conta di più | Perché |
|---|---|---|
| Gestionale | Disponibilità, poi integrità | Se è fermo non si fattura e non si spedisce. Se qualcuno cambia un prezzo o un IBAN senza che si veda, è peggio. |
| Posta | Riservatezza | Dentro ci sono offerte, contratti, e la fiducia dei fornitori. È anche da lì che partono le truffe del bonifico. |
| File server | Integrità e disponibilità | Un ransomware lo cifra: viola tutte e due. |
| PLC di produzione | Disponibilità | Nessuno vuole leggerli. Tutti vogliono che vadano. |
| Buste paga | Riservatezza | Basta che le legga la persona sbagliata. |

Fatto questo schema, le decisioni vengono da sole. Il primo backup va sul file server e sul gestionale. Il secondo fattore va sulla posta. I PLC vanno messi in una rete dove nessuno li raggiunge per sbaglio (ne parliamo nella lezione 9).

## Gli errori che vedo più spesso

- **Trattare tutto come segreto.** Se tutto è riservato, niente lo è davvero, e si finisce per proteggere male le tre cose che contano.

- **Pensare che il backup risolva tutto.** Il backup serve alla disponibilità e, in parte, all'integrità. Contro un furto di dati non fa niente.
- **Confondere vulnerabilità e rischio.** «Lo scanner ha trovato trecento vulnerabilità» non dice quanto rischi. Dipende da dove sono, da chi le può raggiungere e da cosa c'è dietro.
- **Dimenticare la minaccia.** Le minacce reali sono poche e sempre le stesse: ransomware, truffa del bonifico, furto delle credenziali di posta, il fornitore con l'accesso remoto. Conviene ragionare su quelle, non su scenari da film.

## Come lo verifichi

Per ogni sistema del tuo elenco fatti tre domande e scrivi le risposte accanto:

1. Chi non deve poterlo leggere? (riservatezza)
2. Cosa succede se qualcuno lo modifica senza che ce ne accorgiamo? (integrità)
3. Per quante ore può stare fermo prima che sia un problema serio? (disponibilità)

La terza risposta, in ore, è il numero più utile che avrai in mano per tutto il resto delle lezioni: decide il tipo di backup, se serve un ricambio, e quanto puoi aspettare prima di chiamare qualcuno.

CON L'AI, PER QUESTA LEZIONE

**Uso 1 di 12 · L'assistente come interlocutore.** È il modo più semplice, e per la prima lezione basta: ragionare ad alta voce con qualcuno che fa domande. Fai l'elenco dei sistemi come viene, anche disordinato, e falle fare la prima classificazione. Poi correggila tu.

```
Faccio l'informatico da solo in un'azienda di [N] persone. Questi sono i
sistemi che usiamo: [elenco]. Per ognuno dimmi se conta di più la
riservatezza, l'integrità o la disponibilità, spiegami perché in una riga, e
fammi le domande che ti servono se non ti basta quello che ho scritto.
```

Una regola che vale per tutte le lezioni: all'assistente non si danno password, chiavi, indirizzi pubblici dell'azienda né dati dei clienti. Con «gestionale», «posta», «file server» ragiona lo stesso. Nelle prossime lezioni vediamo undici modi diversi di usarla, dal più semplice al più delicato.

DA FARE

## Lunedì mattina, se sei l'unico informatico

1. Scrivi su un foglio i cinque sistemi senza i quali l'azienda si ferma. Di solito sono gestionale, posta, file server, produzione e centralino. ☐
2. Per ognuno segna cosa conta di più: che nessuno lo legga, che nessuno lo modifichi, o che funzioni. Per il gestionale di solito è che funzioni, per le buste paga che nessuno le legga. ☐
3. Tieni il foglio: nelle prossime lezioni ti dice dove mettere il primo backup e il primo secondo fattore. ☐

## Glossario

Le sigle usate in questa lezione. Per ognuna due righe: la prima per capirsi, la seconda per capire. Il glossario cresce di lezione in lezione: le sigle nuove sono segnate, le vecchie restano.

**CIA** NUOVA — Le tre cose da proteggere: riservatezza, integrità, disponibilità (in inglese Confidentiality, Integrity, Availability). Niente a che vedere con l'agenzia americana. *Per capirla meglio:* È il modo più usato per ragionare su cosa serve a un sistema. Ogni attacco colpisce almeno una delle tre: un furto di dati la riservatezza, un ransomware l'integrità e la disponibilità, un guasto la disponibilità. Quando valuti un sistema, chiediti quale delle tre pesa di più: la risposta decide che tipo di protezione gli serve.

**ransomware** NUOVA — Un programma che cifra i file dell'azienda e chiede un riscatto per la chiave. Non è una sigla, ma è la parola che torna più spesso. *Per capirla meglio:* Oggi quasi sempre prima copia i dati fuori e poi li cifra, così può minacciare anche di pubblicarli. Entra con un phishing o da un accesso remoto esposto, poi cerca le password e arriva ai server e ai backup. La difesa sta nelle lezioni 4, 7 e 9: fermare una fase, il secondo fattore, la rete a zone, e un backup che dalla rete non si raggiunge.

**DDoS** NUOVA — Attacco che manda a un servizio più richieste di quante ne regga, finché smette di rispondere. Sta per Distributed Denial of Service. *Per capirla meglio:* «Distribuito» perché le richieste arrivano da migliaia di computer insieme, spesso infettati senza che i proprietari lo sappiano. Non ruba niente: ferma. Il bersaglio tipico è il sito o il portale esposto; la difesa sta quasi sempre dal fornitore che ospita il servizio, non in azienda.

**HTTPS** NUOVA — La versione cifrata di HTTP, il protocollo delle pagine web. È il lucchetto nel browser. *Per capirla meglio:* Cifra il traffico fra il browser e il sito, così chi è in mezzo (sulla rete, sul WiFi) non legge e non modifica. Protegge il percorso, non il sito: una pagina di phishing può avere il lucchetto, e spesso ce l'ha. Il lucchetto dice «stai parlando in modo cifrato con qualcuno», non «quel qualcuno è onesto».

**PLC** NUOVA — Il computer industriale che comanda una macchina o una linea di produzione (Programmable Logic Controller). *Per capirla meglio:* È un apparato fatto per funzionare per vent'anni, non per essere aggiornato: spesso non si può mettere né antivirus né patch. Per questo si protegge dalla rete: va in una zona dove nessuno lo raggiunge per sbaglio, e si guarda chi gli parla.

**IBAN** NUOVA — Il codice del conto corrente, quello che si scrive per fare un bonifico (International Bank Account Number). *Per capirla meglio:* Nella sicurezza compare perché è il bersaglio della truffa del bonifico: cambiare l'IBAN su una fattura vera, o chiedere di cambiarlo in anagrafica, basta per dirottare un pagamento. Ogni cambio di IBAN va verificato per telefono, al numero che si aveva già.

**AI** NUOVA — Intelligenza artificiale. Qui vuol dire gli assistenti con cui si parla scrivendo, e i modelli che ci stanno dietro. *Per capirla meglio:* Nelle lezioni la usiamo come aiuto per il lavoro di sicurezza, con una regola fissa: non le si danno password, chiavi, indirizzi pubblici dell'azienda né dati dei clienti. E quello che risponde è un'ipotesi da verificare, non una fonte: le versioni colpite da una vulnerabilità si controllano sull'NVD, i comandi per uno switch si provano su una porta sola.

---

**Ing. Alessandro Manneschi**
Cyber Security Architect · NIS2, monitoraggio e sicurezza per le PMI

Tutte le lezioni, gratis:
**github.com/alevento/sicurezza-per-chi-e-solo**
Licenza CC BY-NC-SA 4.0